

Synthèse sur la Démarche d'Audit d'un Système d'Information

Résumé Exécutif

Ce document de synthèse détaille les principes fondamentaux et le déroulement de la démarche d'audit appliquée aux systèmes d'information. L'objectif principal d'un audit est de fournir une visibilité claire et impartiale sur le fonctionnement des processus d'une organisation, d'évaluer leur efficacité et d'identifier les axes d'amélioration. La démarche repose sur un référentiel de management qui formalise les règles et l'organisation de l'entreprise.

Les audits se classent en plusieurs catégories : **internes** (menés par l'entreprise) ou **externes** (par un tiers), et se distinguent par leur finalité : **d'évaluation** (conformité à un référentiel) ou **d'investigation** (analyse d'une situation spécifique). Le processus d'audit se déroule systématiquement en quatre phases clés :

1. **Lancement** : Définition des objectifs et du périmètre, choix de l'équipe, et rédaction d'un plan d'audit formel.
2. **Exécution** : Conduite des entretiens et des observations sur le terrain, encadrée par une réunion d'ouverture et une réunion de clôture. Les constats sont classifiés en points forts, conformités, et non-conformités (mineures ou majeures) selon leur impact.
3. **Production du rapport** : Rédaction d'un rapport détaillé qui synthétise les constats, les écarts, et les recommandations. Ce rapport est approuvé par les audités avant diffusion.
4. **Suivi de l'audit** : Les audités élaborent un plan d'actions pour traiter les non-conformités. Ce plan, qui distingue les actions de réparation, correctives et préventives, est validé et suivi par les auditeurs, pouvant mener à un audit de contrôle pour vérifier l'efficacité des mesures prises. La recherche des causes racines, via des méthodes comme les **5 Pourquoi** et les **5M (Ishikawa)**, est une étape cruciale pour garantir que les actions correctives sont pertinentes et durables.

1. Principes Fondamentaux de l'Audit

Objectifs de l'Audit

La finalité d'un audit est double :

- **Donner de la visibilité** sur le fonctionnement des processus d'une entité (entreprise, organisation, projet, produit) et évaluer leur efficacité.
- **Fournir une vue impartiale** par un tiers sur un processus ou un produit, afin d'identifier des opportunités d'amélioration.

Le Référentiel : Base de Tout Audit

Le référentiel de management est le document central de tout audit. Il contient l'organisation et l'ensemble des règles applicables au sein de l'entreprise. Pour être efficace, il doit être :

- Accessible à tous et à tout moment.
- Mis à jour.
- Largement et complètement diffusé.

Une certification comme **ISO 9001:2015** permet de démontrer aux clients que les pratiques de l'entreprise sont efficaces et fiables.

Exemple de Processus Métier et SI

Un référentiel décompose l'activité en processus. Par exemple, le processus de **recrutement** transforme un besoin (donnée d'entrée) en une embauche (donnée de sortie) via une série d'activités intermédiaires. L'audit s'assure que ces activités sont correctement cadrées et exécutées.

Dans le contexte d'un Système d'Information (SI), le référentiel s'articule souvent autour de trois grands groupes de processus :

Groupe de Processus	Description et Exemples
Management (M)	Gère la relation contractuelle, la gestion de projet, la maintenance, la gestion de la transition et la clôture des contrats.
Ingénierie (E)	Concerne la conception et le développement du SI : architecture, gestion des exigences (cahier des charges), développement des composants, tests (ex: processus de tests E3), et déploiement.
Support (S)	Fournit un soutien transverse à la réalisation du SI : gestion des configurations, de la qualité (Plan d'Assurance Qualité, revues PDCA), des indicateurs (KPI), des risques et des estimations (coûts, charges, durée).

Démarche de l'Audit

La démarche d'audit vise à :

- S'assurer que le système de management est correctement appliqué.
- Évaluer l'efficacité des processus en vérifiant si les objectifs sont atteints et les dispositions prévues mises en œuvre.
- Analyser les non-conformités, en rechercher les causes pour élaborer un plan d'actions.
- Identifier les risques associés aux non-conformités.
- Proposer des recommandations d'amélioration (spécifiquement dans le cas d'un audit interne).

Typologie des Audits

Les audits peuvent être classifiés selon leur origine et leur objectif.

Type d'Audit	Description	Sujet d'Observation
Audit Interne	Conduit par la direction de l'audit de l'entreprise elle-même.	Organisation interne, projet, département.
Audit Externe	Réalisé par un tiers : cabinet extérieur, organisme de certification (AFAQ, AFNOR), ou la direction de l'audit d'un client.	L'entreprise ou une partie de ses activités.
Audit d'Évaluation (Audit Système)	Fait partie de l' audit initial . Vise à évaluer le degré de conformité d'un système à un référentiel, en déduire les risques potentiels et proposer des recommandations.	Une organisation (département, service) ou un projet spécifique.
Audit d'Investigation (Audit Ponctuel)	Fait partie de l' audit initial . Réalisé à la demande pour expliciter une situation, en déterminer les causes, évaluer les risques et proposer des recommandations.	Une organisation, un projet, un produit, un service ou un fournisseur.
Audit de Contrôle	Audit de suivi qui a pour but de vérifier la mise en œuvre effective des actions décidées lors d'un audit initial.	Les actions correctives et préventives issues d'un audit précédent.

Déclenchement d'un Audit

Le motif de déclenchement dépend du type d'audit :

- **Audits d'évaluation** : Généralement inscrits dans un **plan annuel d'audits** qui cible des produits, projets, services ou activités spécifiques.
- **Audits d'investigation** : Déclenchés à la **demande** (interne ou externe) en réponse à des événements tels que :
 - Un constat de défaut ou de dysfonctionnement.
 - Un constat de risque.
 - Des changements dans le système de management ou une réorganisation.
 - Une perte de confiance.

Rôles et Responsabilités

Le processus d'audit implique plusieurs acteurs aux responsabilités bien définies.

Acteur	Rôles et Responsabilités Clés
Le Demandeur	- Décide des éléments à auditer et définit les objectifs, le périmètre et les délais avec le responsable des audits. - S'assure de la disponibilité des audités. - Est le destinataire du rapport d'audit.
Le Responsable des Audits (ou Auditeur Principal)	- Organise l'audit : établit le plan d'audit (qui vaut lettre de mission), sert d'interlocuteur au demandeur. - Encadre l'équipe : affecte les auditeurs selon leurs compétences et anime l'équipe. - Contrôle le suivi : valide le plan d'actions des audités et vérifie l'efficacité des actions correctives.
L'Équipe d'Auditeurs	- Agit en toute indépendance et dans le respect de la déontologie. - Mène les entretiens conformément au planning, recueille les preuves et relève les indices. - Analyse les observations et évalue les interactions. - Rédige le rapport d'audit .
Les Audités	- Désignent un représentant unique. - Coopèrent pleinement avec les auditeurs, facilitent le déroulement de l'audit et donnent accès aux informations et installations. - Construisent le plan d'actions suite à la réception du rapport d'audit.

2. Déroulement Détaillé du Processus d'Audit

Le déroulement d'un audit est structuré en quatre phases séquentielles.

Phase 1 : Lancement de l'Audit

Cette phase préparatoire est essentielle au succès de la mission.

1. **Définition des objectifs et du périmètre** : Clarifier ce qui sera audité et pourquoi.
2. **Choix de l'équipe d'audit** : Sélectionner des auditeurs ayant les compétences requises.
3. **Préparation du questionnaire d'audit** : Élaborer une série de questions basées sur le référentiel. Ce questionnaire sert de **fil conducteur** et non d'outil d'interrogatoire.
4. **Élaboration du plan d'audit** : Ce document **obligatoire** formalise l'organisation de la mission. Il contient :
 - Les documents de référence et critères de l'audit.
 - Le périmètre précis (fonctions, projets, responsables audités).
 - La composition de l'équipe d'audit.
 - Les dates, la durée, et le planning détaillé des interventions.

- La localisation et l'organisation logistique.
- Les modalités de suivi (rapport, plan d'actions, audit de contrôle).

5. **Information des acteurs** : Le plan d'audit est diffusé à toutes les parties prenantes.

Phase 2 : Exécution de l'Audit

C'est la phase de collecte d'informations sur le terrain.

1. **Réunion d'ouverture : Obligatoire**, elle marque le début officiel de la mission. Elle rassemble auditeurs, audités et leurs responsables hiérarchiques pour présenter le plan d'audit (objet, équipe, démarche, planning).
2. **Entretiens, visites et constats** : Les auditeurs recueillent les constats via :
 - L'étude de documents.
 - Des entretiens individuels ou de groupe.
 - Des visites directes sur le terrain. Les informations sont systématiquement recoupées et vérifiées par croisement des sources.
3. **Évaluation et classification des constats** : La maîtrise des processus est évaluée et chaque constat est classifié.

Classification	Description	Impact pour le Projet
Point Fort	Domaine très bien maîtrisé ; les pratiques vont au-delà du référentiel.	À conserver et potentiellement à généraliser.
Conforme	Domaine maîtrisé ; le processus est efficace et le référentiel respecté (pas d'écarts).	Rien à signaler.
Non-conformité mineure	Domaine partiellement maîtrisé ; objectifs partiellement atteints.	Risques faibles : ralentissement, faible retard.
Non-conformité majeure	Domaine non maîtrisé ; objectifs non atteints.	Risques forts : arrêt ou retard important.

1. **Réunion de clôture : Obligatoire**, elle présente une synthèse des résultats (points forts, écarts, points sensibles) et informe les audités de la suite du processus (droit de réponse, délai pour le plan d'actions, audit de contrôle éventuel).

Phase 3 : Production du Rapport d'Audit

Cette phase formalise les conclusions de la mission.

1. **Rédaction du rapport** : Rédigé par les auditeurs, il contient :
 - Le cadre de la mission.
 - Les conclusions et la synthèse (points forts, écarts majeurs/mineurs, points sensibles, propositions d'amélioration).
 - Un tableau commenté du niveau de maîtrise des processus audités.
 - Un rappel du référentiel pour chaque écart majeur constaté.
2. **Approbation et diffusion** : Le rapport est soumis aux audités pour approbation avant d'être diffusé à tous les acteurs concernés. La fin de cette phase marque la fin de l'audit initial.

Phase 4 : Suivi de l'Audit

Cette phase vise à s'assurer que les non-conformités sont corrigées durablement.

1. **Élaboration du plan d'actions** : Rédigé par les **audités**, ce plan détaille les actions à mener pour corriger les écarts.

2. **Typologie des actions** :

Type d'Action	Objectif	Caractéristiques	Exemple (Vol d'un ordinateur)
Action de réparation	Éliminer une non-conformité détectée.	Agit sur le produit (effet). S'applique à une réparation ou une reprise.	Racheter un ordinateur.
Action corrective	Éliminer la cause d'une non-conformité détectée pour empêcher sa réapparition.	Agit sur la cause racine.	Ranger l'ordinateur dans un meuble fermant à clé.
Action préventive	Éliminer la cause d'une non-conformité potentielle pour empêcher son occurrence.	Agit sur une cause potentielle.	Sécuriser l'entrée du bâtiment avec un badge et sensibiliser les salariés.

1. **Validation et suivi** : Le plan d'actions est validé par l'auditeur, puis son exécution est suivie par les audités.
2. **Audit de contrôle** : Un audit de suivi peut être planifié pour vérifier la bonne exécution et l'efficacité des actions. L'audit est clôturé lorsque toutes les non-conformités sont corrigées.

Méthodes de Recherche des Causes Racines

Pour que les actions correctives soient efficaces, il est impératif d'identifier la cause origine du dysfonctionnement.

- **Méthode des 5 Pourquoi** : Consiste à se poser la question "Pourquoi ?" de manière répétée (environ 5 fois) pour remonter des symptômes à la cause racine sur laquelle il est possible d'agir. L'analyse doit rester factuelle et se concentrer sur les causes contrôlables.
- **Méthode des 5M (Ishikawa)** : Vise à identifier et classer les causes possibles d'un dysfonctionnement en 5 catégories :
 - **Main d'œuvre** : formation, compétences, motivation, management.
 - **Moyens / Matériels** : équipements, postes de travail, serveurs, outils.
 - **Méthode** : instructions, modes opératoires, procédures.
 - **Matière** : éléments d'entrée, documents, cahier des charges, spécifications.
 - **Milieu** : environnement, bureaux, marché, client, législation. Cette méthode peut être couplée avec les 5 Pourquoi pour une analyse exhaustive.
- **Démarche CRIME** : Une structure globale pour la gestion des dysfonctionnements :
 - Caractériser le dysfonctionnement.
 - Régler le dysfonctionnement (réparation).
 - Identifier la cause origine.
 - Mettre en œuvre les actions correctives/préventives.
 - Évaluer l'efficacité des actions et assurer le suivi.